

Informe de Seguridad Piedra Azul



SANTIAGO ENRIQUE BASTIDAS ESTRADA

BIBIANA SOFIA CORTES MONTILLA

JOSE ALEJANDRO RODRIGUEZ DUEÑAS

GLENN ALEXANDER WARD ANTE

Ingeniería de Software III

Profesor:

FRANCISCO JAVIER OBANDO VIDAL

Universidad del Cauca

Facultad de Ingeniería Electrónica y Telecomunicaciones

Departamento de Sistemas

Ingeniería del Software III

Popayán, Mayo 2026

1. Introducción.....	3
Resumen de Hallazgos.....	3
2. Revelación de PII.....	3
Descripción.....	4
Impacto.....	4
Solución Recomendada.....	4
3. CSP sin Directivas Fallback.....	4
Descripción.....	5
Impacto.....	5
Solución Recomendada.....	5
4. XSS Potencial (Atributo HTML Controlable).....	5
Descripción.....	5
Impacto.....	6
Solución Recomendada.....	6
5. Información Sensible en URL.....	6
Descripción.....	6
Impacto.....	6
Solución Recomendada.....	6
6. Conclusiones.....	7

1. Introducción

Se realizaron pruebas de seguridad automatizadas sobre el backend del proyecto de la clínica Piedra Azul utilizando OWASP ZAP 2.17.0. El escaneo se ejecutó contra el servidor local en <http://localhost:8080>, identificando un total de 5 alertas, de las cuales 4 corresponden a vulnerabilidades clasificadas según el estándar OWASP Top 10.

Resumen de Hallazgos

#	Vulnerabilidad	Categoría OWASP	CWE	Severidad
1	Revelación de PII	A04:2021 / A06:2025	CWE-359	Alta
2	CSP sin directivas Fallback	A02:2021 / A06:2017	CWE-693	Media
3	XSS Potencial	A03:2021 / A05:2025	CWE-20	Info
4	Info. Sensible en URL	A02:2021	CWE-598	Info

Alertas (5)
> Revelación PII
> CSP: Failure to Define Directive with No Fallback (Systemic)
> Atributo de elemento HTML controlable por el usuario (XSS potencial) (1.514)
> Divulgación de Información - Información sensible en URL (Systemic)
> Petición de Autenticación Identificada (2)

2. Revelación de PII

Campo	Detalle
Categoría OWASP	A04:2021 Insecure Design / A06:2025 Insecure Design
Severidad	Alta (High)
Confianza	Medium
CWE	CWE-359 — Exposure of Private Personal Information to Unauthorized Actor

WASC ID	13
URL Afectada	http://localhost:8080/UI/break/view/isBreakAll/override?apikey=ZAP
Evidencia	2575783592598165 (formato número de tarjeta Mastercard detectado)
Origen	Pasivo (10062 - Revelación PII)

Descripción

La respuesta del servidor contiene Información de Identificación Personal (PII). Específicamente, ZAP detectó en el cuerpo de la respuesta un valor numérico que coincide con el patrón de un número de tarjeta de crédito Mastercard (2575783592598165). Esto indica que datos sensibles de usuarios podrían estar siendo expuestos a través de las respuestas de la API sin ningún tipo de enmascaramiento o filtrado.

Impacto

Un atacante que intercepte las respuestas del servidor (ej. mediante un ataque Man-in-the-Middle) podría obtener números de tarjeta de crédito, documentos de identidad u otros datos sensibles de los pacientes, violando regulaciones como PCI-DSS y la normativa de protección de datos.

Solución Recomendada

Revisar todos los endpoints de la API para asegurarse de que las respuestas no incluyan datos sensibles en texto plano. Implementar enmascaramiento de datos en los DTOs de respuesta (por ejemplo, mostrar solo los últimos 4 dígitos de una tarjeta). Aplicar el principio de mínimo privilegio en la información retornada.

3. CSP sin Directivas Fallback

Campo	Detalle
Categoría OWASP	A02:2021 Cryptographic Failures / A06:2017 Security Misconfiguration
Severidad	Media (Medium)
Confianza	High
CWE	CWE-693 — Protection Mechanism Failure
WASC ID	15
URL Afectada	http://localhost:8080
Parámetro	Content-Security-Policy

Directivas faltantes	frame-ancestors, form-action
Evidencia	default-src 'none'; script-src 'self'; connect-src 'self'; child-src 'self'...

Descripción

La política Content Security Policy (CSP) definida en el servidor no incluye las directivas frame-ancestors ni form-action. Estas directivas no heredan su valor de default-src, por lo que omitirlas equivale a no tener ninguna restricción para esos vectores. Esto deja la aplicación expuesta a ataques de Clickjacking (mediante iframes maliciosos) e inyección de formularios desde orígenes externos.

Impacto

Un atacante podría embeber la aplicación dentro de un iframe en un sitio malicioso (Clickjacking), engañando a usuarios legítimos para que realicen acciones no intencionadas. También podría redirigir el envío de formularios a servidores bajo su control para robar credenciales.

Solución Recomendada

Agregar las directivas faltantes en la configuración de Spring Security (SecurityConfig.java):

```
.headers(headers -> headers
    .contentSecurityPolicy(csp -> csp
        .policyDirectives("default-src 'self'; frame-ancestors 'none'; form-action 'self'")
    )
)
```

4. XSS Potencial (Atributo HTML Controlable)

Campo	Detalle
Categoría OWASP	A03:2021 Injection / A05:2025 Injection
Severidad	Informacional (requiere revisión manual)
Confianza	Low
CWE	CWE-20 — Improper Input Validation
URL Afectada	http://localhost:8080/UI/alert/view/alert/override?apikey=ZAP&id=ZAP
Parámetro	apikey
Evidencia	El valor de 'apikey' se refleja en el atributo id de un elemento <form>

Descripción

ZAP detectó que el parámetro apikey enviado por el usuario en la URL se refleja sin sanitizar en un atributo HTML del DOM (específicamente en el atributo id de un elemento form). Si un atacante puede controlar este valor e inyectar caracteres especiales como comillas o signos de mayor/menor, podría ejecutar scripts maliciosos en el navegador de la víctima (Cross-Site Scripting).

Impacto

Explotación exitosa permitiría robo de sesiones, redirección a sitios maliciosos, o ejecución de acciones en nombre del usuario autenticado sin su consentimiento.

Solución Recomendada

Validar y sanitizar toda entrada de usuario antes de escribirla en atributos HTML. Nunca reflejar parámetros de URL directamente en respuestas HTML sin escapado. Utilizar librerías como OWASP Java HTML Sanitizer para el manejo de entradas.

5. Información Sensible en URL

Campo	Detalle
Categoría OWASP	A02:2021 Cryptographic Failures
Severidad	Informacional
Confianza	Medium
CWE	CWE-598 — Use of GET Request Method with Sensitive Query Strings
URL Afectada	http://localhost:8080/UI/clientSpider/action/scan/override?...&userName=ZAP
Parámetro	userName
Evidencia	El campo 'userName' aparece como query parameter en la URL

Descripción

El parámetro userName se está transmitiendo como query parameter en la URL mediante método GET. Las URLs son registradas en logs de servidores, historial del navegador, servidores proxy y cabeceras Referer, por lo que cualquier dato sensible enviado de esta forma puede ser expuesto inadvertidamente a terceros no autorizados.

Impacto

Nombres de usuario expuestos en logs podrían facilitar ataques de enumeración de usuarios, phishing dirigido, o ser usados para cruzar información con otras fuentes de datos comprometidas.

Solución Recomendada

Nunca enviar datos sensibles como username, contraseñas o tokens en la URL. Utilizar el cuerpo de la petición (body) con método POST o incluirlos en headers de autorización como Authorization: Bearer <token>.

6. Conclusiones

El análisis de seguridad realizado con OWASP ZAP sobre el backend del proyecto PiedraAzul identificó vulnerabilidades clasificadas en tres categorías del OWASP Top 10. El hallazgo más crítico corresponde a la Revelación de PII (severidad Alta), que podría comprometer datos sensibles de los pacientes. Se recomienda priorizar la corrección en el siguiente orden:

1. Revelación de PII — Filtrar datos sensibles en respuestas de la API.
2. CSP sin Fallback — Agregar directivas frame-ancestors y form-action en SecurityConfig.java.
3. XSS Potencial — Sanitizar entradas reflejadas en atributos HTML.
4. Info. Sensible en URL — Mover datos sensibles al body de la petición.